

Wi-Fi and Cloud Security Practices

Securing wireless networks · virtual platforms and cloud services · web application security



Lesson 1

Wi-Fi: **WPA2/WPA3** (Wi-Fi Protected Access 2 / Wi-Fi Protected Access 3),
passphrases, guest zone



Lesson 2

Virtualization and cloud: **AWS** (Amazon
Web Services) and Azure



Lesson 3

Web applications: common
vulnerabilities

Tuesday, September 29, 2026 · Cybersecurity AEC (Attestation d'études collégiales), LEA.D8 · Competency EZ03: to apply access control measures · Cohort CYB-01, Fall 2026 · Case company: NorthMaple Accounting Inc. (fictional)

Legal Notice and Acceptable Use (1/2)



What this material is

- All lectures, labs, projects, quizzes, documents and videos of this course are for **education only**: they teach how to **protect** systems, not how to attack the systems of others.
- Nothing in this class is an invitation, an instruction or an authorization to access, test or damage any real system, network, account or data.
- You are fully and solely responsible for your own actions, equipment, accounts, costs and time.
- Reading, watching, downloading or using any part of the material means you accept the whole Legal Notice, Disclaimer and Acceptable Use Policy (version 1.0).



You may

- Practice only in **your own isolated laboratory**: VirtualBox, or your own free-tier **AWS** (Amazon Web Services) or Microsoft Azure account, as defined in LAB_01.
- Practice on another system only with the owner's **explicit written permission**, obtained before you start.
- Use snapshots and isolated virtual networks so that a mistake stays inside your laboratory.



Sign today's acknowledgment

At the start of each session, open the **Acknowledgment and Agreement** page
(`Acknowledgment_and_Agreement_eSign.html`), sign it, and submit your signature record (§16).

Legal Notice and Acceptable Use (2/2)



You must never

- Scan, probe, attack, intercept, monitor or access any system, network, **wireless network** or account that is not yours: the college's, an employer's, a business's, a public website's or a neighbour's.
- Create, install or release malicious software outside your isolated laboratory.
- Attempt password, credential or interception attacks against any real account or any real communication.
- Use the material, or any tool shown in it, to break any law or policy that applies to you.



The law

- Criminal Code of Canada: **s. 342.1** unauthorized use of a computer; **s. 342.2** possession of a device to obtain unauthorized use of a computer; **s. 430(1.1)** mischief in relation to computer data. Penalties can include imprisonment.
- Outside Canada, the laws of your own country, province or state apply to you. College policies and codes of conduct apply in addition.
- If an activity seems to touch a system you do not own: **stop and ask the instructor** before doing anything.



You use the material at your own risk, on your own equipment and time (§5). Today's topics — Wi-Fi, cloud accounts and web applications — are exactly where this rule applies.

Sources: <https://laws-lois.justice.gc.ca/eng/acts/c-46/section-342.1.html> · <https://laws-lois.justice.gc.ca/eng/acts/c-46/section-430.html>



From Class 12 to today

Class 12: the LAB_01 zoning table became real firewall rules on NM-FW01. Every rule answered one question:

Which zone may start a connection toward which other zone, on which service?

Today, the same question in three places:



The radio signal of the office Wi-Fi

Lesson 1 — the protected system is not a cable and a switch port



Virtual machines and cloud accounts

Lesson 2 — the protected system is not a cable and a switch port



A web application anyone can reach

Lesson 3 — the protected system is not a cable and a switch port



At the end of this class you can...

1. Explain how **WPA2** (Wi-Fi Protected Access 2) and **WPA3** (Wi-Fi Protected Access 3) protect a wireless link, and why **WPA3** resists offline passphrase guessing.
2. Calculate passphrase strength in bits and write a passphrase rule that follows **NIST** (National Institute of Standards and Technology) and **CCCS** (Canadian Centre for Cyber Security) guidance.
3. Design a guest Wi-Fi zone for NorthMaple Accounting Inc. with its firewall rules.
4. State what the customer secures under the shared responsibility model, and review security groups, **NSGs** (Network Security Groups) and cloud identities.
5. Recognize common web vulnerabilities of the **OWASP** (Open Worldwide Application Security Project) Top 10:2025 and the defenses to require before LAB_06.

LESSON 1

Securing wireless networks

Real-life example 1 · Program 1 · 3 videos

1.1 Why Wi-Fi needs its own protections

1.2 From **WEP** (Wired Equivalent Privacy) to **WPA3** (Wi-Fi Protected Access 3)

1.3 From passphrase to key

1.4 Strong passphrases

1.5 Guest and corporate zones



LESSON 1 · 1.1 WHY WI-FI NEEDS ITS OWN PROTECTIONS

A radio network has no walls

- A **WLAN** (Wireless Local Area Network) is reached through radio: the **IEEE** (Institute of Electrical and Electronics Engineers) 802.11 standards, certified under the Wi-Fi brand, use the 2.4, 5 and 6 **GHz** (gigahertz) bands.
- Every receiver in range can record every frame, including one in the parking lot or on the floor above.
- **Access point**: the device that connects wireless clients to the wired network (NM-AP01, management address 192.168.20.30).
- **SSID** (Service Set Identifier): the network name announced in **beacon frames**; one access point can announce several **SSIDs** (Service Set Identifiers).
- **Association**: the frame exchange by which a client joins one **SSID**.

What Wi-Fi security must provide



Confidentiality over the air

Every data frame is encrypted; a recorded frame is useless without the key.



Authentication before access

The device proves the secret, or its own credentials, before it gets an address.



Integrity

A frame cannot be modified or replayed without detection.

Settings that do not protect, and the real threats



Two settings that do not protect

- **Hiding the SSID** (Service Set Identifier): clients still send the name in probe requests and association frames, so a receiver learns it within minutes.
- **MAC** (Media Access Control) **address filtering**: **MAC** addresses travel unencrypted in every frame header and can be copied by another device.
- Both can reduce casual connections; **neither replaces encryption and authentication.**



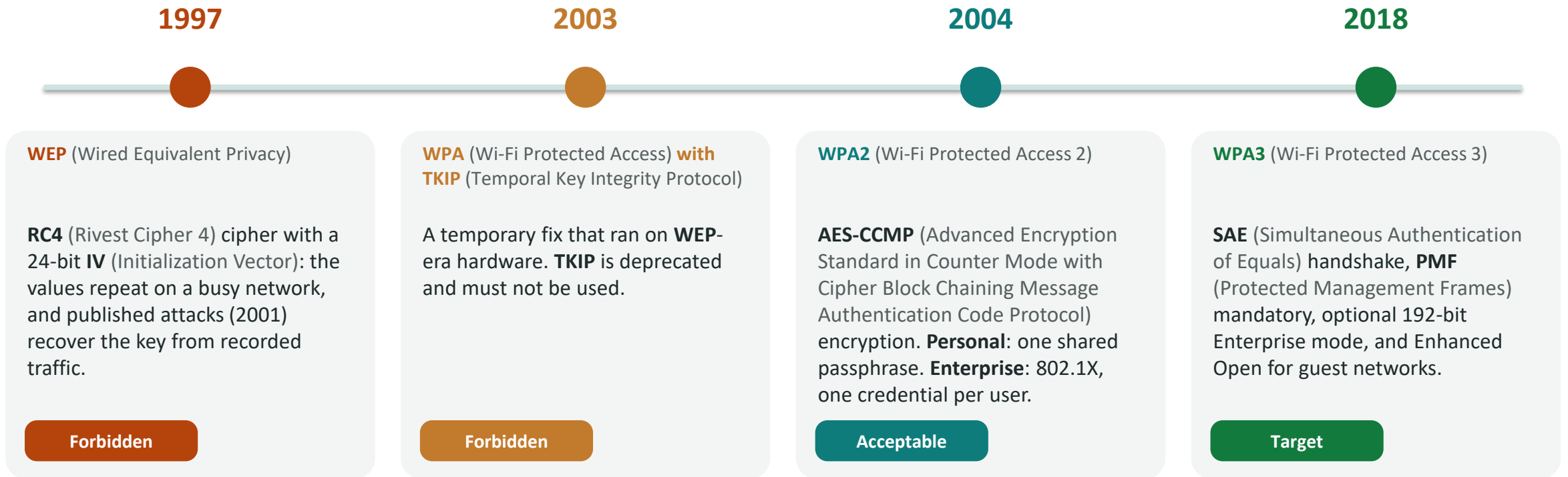
Threats to a small-office Wi-Fi (awareness level)

- Passive recording of traffic
- A **rogue access point** advertising the same **SSID** as the real one (an "evil twin")
- Forged **deauthentication frames** that disconnect clients
- Offline guessing of a passphrase from a recorded handshake
- An access point still using its factory administrator password
- The **WPS** (Wi-Fi Protected Setup) PIN feature



Awareness level only. Never observe, test or connect to a wireless network that you do not own; in the lab, use NM-AP01 as documented (Legal Notice §3–4).

From WEP to WPA3: four generations



Canadian case — TJX / Winners (OPC (Office of the Privacy Commissioner of Canada) report, September 25, 2007): the intruder first entered through the wireless **LANs** (Local Area Networks) of two U.S. stores; the **OPC** found that **WEP** "can be defeated relatively easy"; about **45 million** payment cards were affected.

Source: https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2007/tjx_rep_070925/

What WPA3 adds, and what the CCCS recommends



WPA3-Personal with SAE

SAE (Simultaneous Authentication of Equals) replaces the pre-shared key exchange and protects against offline password guessing.



PMF is mandatory

PMF (IEEE (Institute of Electrical and Electronics Engineers) 802.11w) protects management frames: a forged disconnection frame is rejected.



192-bit Enterprise mode

Optional mode: **GCMP** (Galois/Counter Mode Protocol) encryption with 256-bit keys, **SHA-384** (Secure Hash Algorithm with a 384-bit output) hashing and 384-bit elliptic curves.



Wi-Fi Enhanced Open

OWE (RFC (Request for Comments) 8110) encrypts open networks, but it authenticates no one.



CCCS position (ITSP.80.002)

- The **CCCS** (Canadian Centre for Cyber Security): when it is available, **WPA3** (Wi-Fi Protected Access 3) "should be used for all new deployments".
- A pre-shared key "is not recommended for business use of any kind" (no identity management, no audit).
- **EAP-TLS** (Extensible Authentication Protocol with Transport Layer Security) is the most secure enterprise method.



NorthMaple target

Target: WPA3-Enterprise (Wi-Fi Protected Access 3, Enterprise mode) with certificates. **Lab minimum: WPA3-Personal** (Wi-Fi Protected Access 3, Personal mode) with a strong passphrase, recorded as a known limitation. The 6 **GHz** (gigahertz) band (Wi-Fi 6E) requires **WPA3** or Enhanced Open.

Sources: <https://www.wi-fi.org/discover-wi-fi/security> · <https://www.cyber.gc.ca/en/guidance/wi-fi-security-itsp80002> · <https://www.wi-fi.org/beacon/chuck-lukaszewski/wi-fi-6e-the-details-you-need-to-know>



Wi-Fi security modes compared

Mode	Year	How users authenticate	Radio-link encryption	Offline guessing?	Use at NorthMaple
WEP	1997	One shared key	RC4 with a 24-bit IV	Key recoverable from recorded traffic	Forbidden
WPA (TKIP)	2003	Pre-shared key or 802.1X	TKIP (deprecated)	Yes	Forbidden
WPA2-Personal (PSK)	2004	One shared passphrase	AES-CCMP, 128-bit	Yes: depends only on passphrase strength	Only while old devices remain, with a long random passphrase
WPA2-Enterprise	2004	802.1X / EAP with a RADIUS server, one credential per user	AES-CCMP, 128-bit	No shared passphrase to guess (EAP-TLS uses certificates)	Acceptable
WPA3-Personal (SAE)	2018	Password proven with SAE; PMF required	AES-CCMP, 128-bit	No: each guess needs the access point	Lab minimum for staff; guest SSID
WPA3-Enterprise	2018	802.1X / EAP (EAP-TLS preferred); PMF required	AES-CCMP 128-bit, or 192-bit mode with GCMP-256	No shared passphrase to guess	Target for the staff SSID
Wi-Fi Enhanced Open (OWE)	2018	None (open network)	Individual encryption for each client	Not applicable (no password)	Option for the guest SSID, with a captive portal

Abbreviations: **WEP** (Wired Equivalent Privacy); **RC4** (Rivest Cipher 4); **IV** (Initialization Vector); **WPA** (Wi-Fi Protected Access); **TKIP** (Temporal Key Integrity Protocol); **WPA2-Personal** (Wi-Fi Protected Access 2, Personal mode); **PSK** (Pre-Shared Key); **AES-CCMP** (Advanced Encryption Standard in Counter Mode with Cipher Block Chaining Message Authentication Code Protocol); **WPA2-Enterprise** (Wi-Fi Protected Access 2, Enterprise mode); **EAP** (Extensible Authentication Protocol); **RADIUS** (Remote Authentication Dial-In User Service); **EAP-TLS** (Extensible Authentication Protocol with Transport Layer Security); **WPA3-Personal** (Wi-Fi Protected Access 3, Personal mode); **SAE** (Simultaneous Authentication of Equals); **PMF** (Protected Management Frames); **SSID** (Service Set Identifier); **WPA3-Enterprise** (Wi-Fi Protected Access 3, Enterprise mode); **GCMP** (Galois/Counter Mode Protocol); **OWE** (Opportunistic Wireless Encryption)

Sources: <https://www.wi-fi.org/discover-wi-fi/security> · <https://www.cyber.gc.ca/en/guidance/wi-fi-security-itsp80002>



From passphrase to key: WPA2 versus WPA3



WPA2-Personal (pre-shared key)

PMK = PBKDF2(HMAC-SHA1, passphrase, salt = SSID, 4096 iterations, 256 bits)

- The passphrase is never sent over the air. The **SSID** (Service Set Identifier) is the **salt**: the same passphrase gives a different **PMK** (Pairwise Master Key) on another network.
- **Four-way handshake**: ANonce + SNonce + the two **MAC** (Media Access Control) addresses + **PMK** → **PTK** (Pairwise Transient Key); the **MIC** (Message Integrity Code) proves that the client knows the key.
- A recorded handshake holds every input except the passphrase, so guesses can be checked **offline**, where the access point cannot slow them down or log them.
- **KRACK** (2017) is fixed by software updates of clients and access points.



WPA3-Personal (SAE)

- **SAE** (Simultaneous Authentication of Equals) comes from the Dragonfly key exchange (**RFC** (Request for Comments) 7664): each side proves it knows the password without revealing any value that can be tested offline.
- **Online guessing only**: every guess needs a live exchange with the access point, which can slow down and log failures.
- **Forward secrecy**: fresh random values for every session, so recorded traffic stays protected even if the password leaks later.
- Dragonblood (2019): early implementation flaws and a downgrade of **WPA2/WPA3** (Wi-Fi Protected Access 2 / Wi-Fi Protected Access 3) transition mode; fixed by updates.
- **Rule**: use transition mode only while old devices remain, then **WPA3** (Wi-Fi Protected Access 3) only.

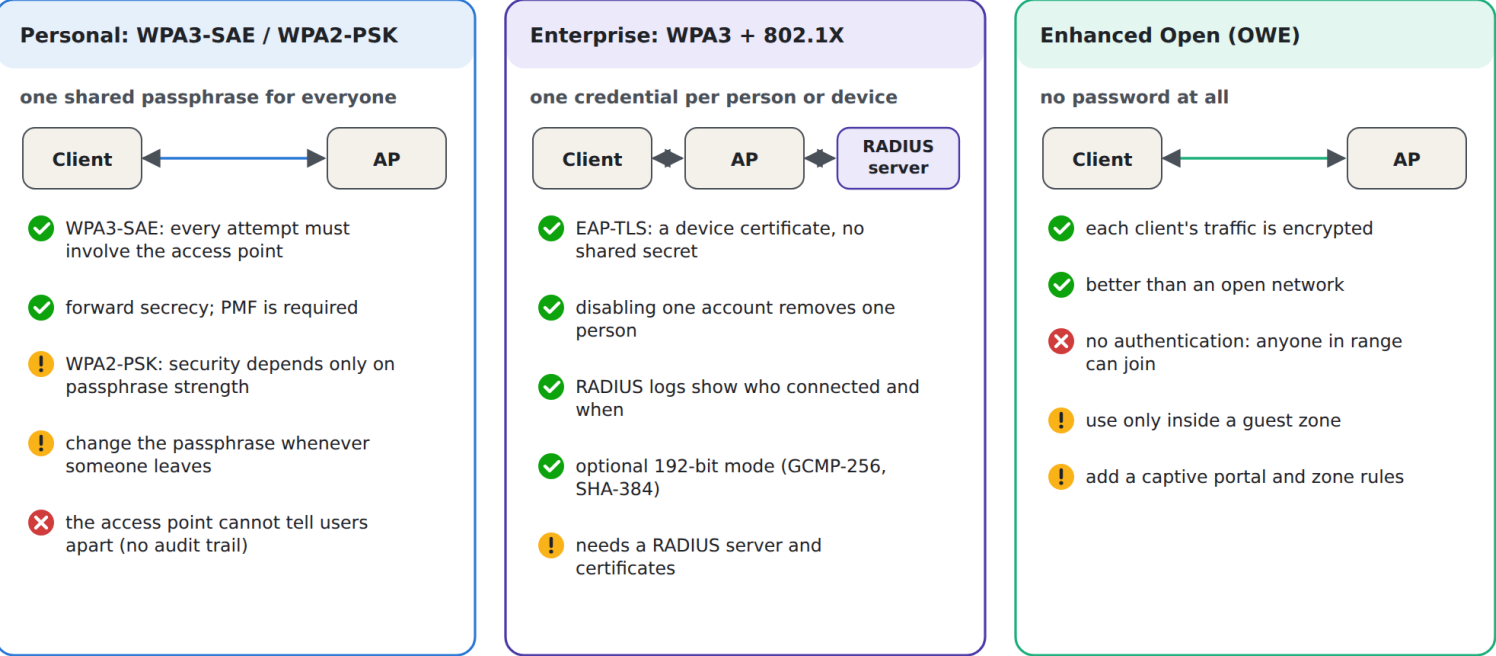
Sources: <https://www.krackattacks.com/> · <https://www.rfc-editor.org/rfc/rfc7664> · <https://wpa3.mathyvanhoef.com/>



Three ways to join a Wi-Fi network

Figure 1.2 - Three ways to join a Wi-Fi network, and what each one protects

Encryption of the radio link is common to all three. They differ in who proves what, and in what the network knows about each user.



NorthMaple decision (Class 13)

Staff SSID: WPA3-Enterprise is the target; WPA3-SAE with 5 random words is the lab minimum.
Guest SSID: WPA3-SAE with a weekly passphrase, or Enhanced Open with a captive portal, always in the Guest zone.

Abbreviations

WPA3 (Wi-Fi Protected Access 3)
PSK (Pre-Shared Key)
PMF (Protected Management Frames)
EAP-TLS (Extensible Authentication Protocol - Transport Layer Security)
GCMP (Galois/Counter Mode Protocol)

SAE (Simultaneous Authentication of Equals)
AP (Access Point)
RADIUS (Remote Authentication Dial-In User Service)
OWE (Opportunistic Wireless Encryption)
SHA (Secure Hash Algorithm)

Cyber.SoHo - Class 13 - Wi-Fi and Cloud Security Practices

How to read it

- All three encrypt the radio link; they differ in **who proves what**.
- **Personal**: one shared passphrase; with **WPA2-PSK** (Wi-Fi Protected Access 2 with a Pre-Shared Key) its strength is the only protection.
- **Enterprise**: one credential per person or device; the **RADIUS** (Remote Authentication Dial-In User Service) logs show who connected.
- **Enhanced Open**: encryption without authentication — only inside a guest zone.

Figure 1.2 — Three ways a device can join a Wi-Fi network. All three encrypt the radio link; they differ in who is authenticated and in what the network can record about each user.

File: C13_Fig1-2_WiFi_Authentication_Modes.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



Passphrase strength: the arithmetic



Entropy of a passphrase chosen at random: $H = L \times \log_2(A)$ bits (L symbols, each from an alphabet of A symbols)
 Expected number of guesses = $N / 2 = 2^{(H-1)}$. **Each extra bit doubles the attacker's work.**

37.6 bits

8 random lowercase letters

Average time: ≈ 1.2 days

51.7 bits

4 random words from the EFF list (7,776 words, 12.9 bits each)

Average time: ≈ 58 years

77.5 bits

6 random words from the same list

Average time: $\approx 3.5 \times 10^9$ years

Assumption: 1,000,000 offline guesses per second (change it in Figure 1.3 and in the spreadsheet). At 10^9 guesses per second the 4-word passphrase falls in ≈ 21 days.

Random choices only. NorthMaple2026! gives $15 \times \log_2(95) \approx 98$ bits on paper, yet company name + year + "!" is exactly what guessing tools try first.

Source: <https://www.eff.org/dice>



Passphrase and device policy



NIST SP 800-63B-4

- **NIST** (National Institute of Standards and Technology) **SP 800-63B-4** (Special Publication 800-63B, revision 4), final version: July 2025.
- At least **15 characters** for a password used alone.
- **No composition rules.**
- **No periodic change**, unless there is evidence of compromise.
- Check new passwords against a **blocklist**.



CCCS (ITSAP.80.009)

- Wi-Fi passphrase of "at least **4 words and 15 characters** in length".
- Limit the period of use of the **guest** password, for example daily expiry or guest passes.



One key shared by many

- Change it when someone who knows it **leaves** or loses a device.
- A **different passphrase for each SSID** (Service Set Identifier).
- Never the company name, the **SSID**, the address or the year.



Access point administrator account

A unique passphrase, never the factory value. Resilience scenario 9 of the Final Project: default credentials on network devices.



WPS disabled

The 8-digit **WPS** (Wi-Fi Protected Setup) PIN is checked in two halves, so at most about **11,000 attempts** are needed.

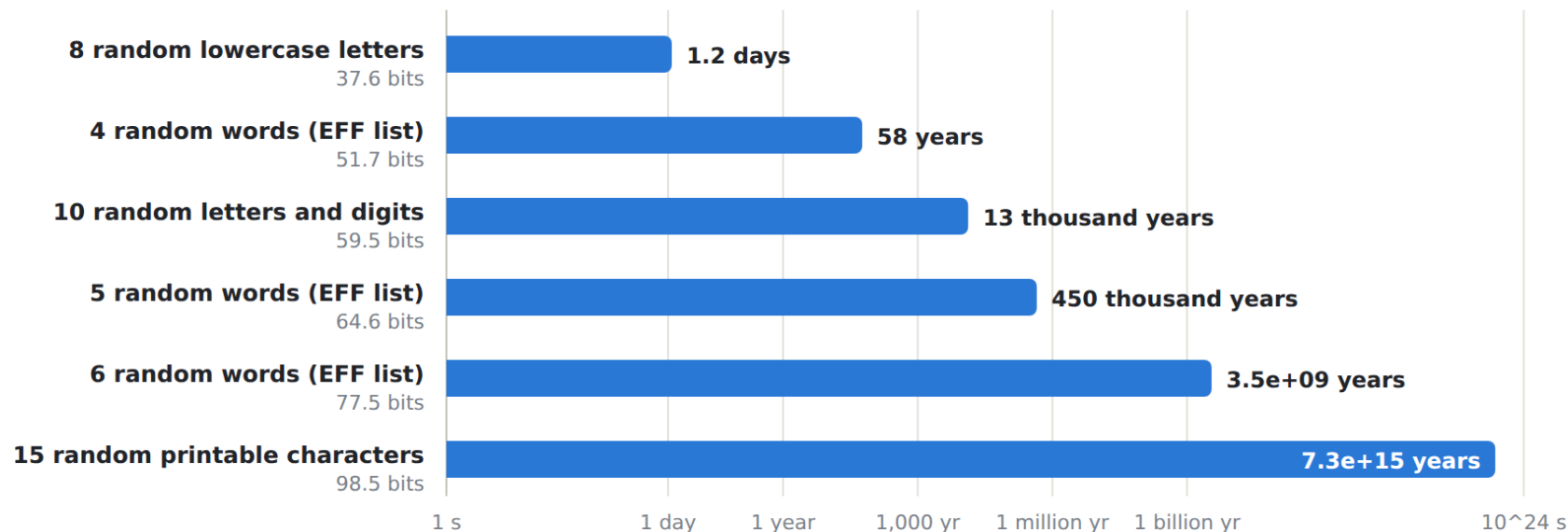
Sources: <https://pages.nist.gov/800-63-4/sp800-63b.html> · <https://www.cyber.gc.ca/en/guidance/protecting-your-organization-while-using-wi-fi-itsap80009>



Expected search time of random passphrases

Figure 1.3 - Passphrase length and expected search time (randomly generated passphrases)

Assumed speed: 1,000,000 guesses per second. Expected guesses = half of all possible values. Logarithmic scale.



Not on this scale: human choices such as guest1234 or NorthMaple2026!

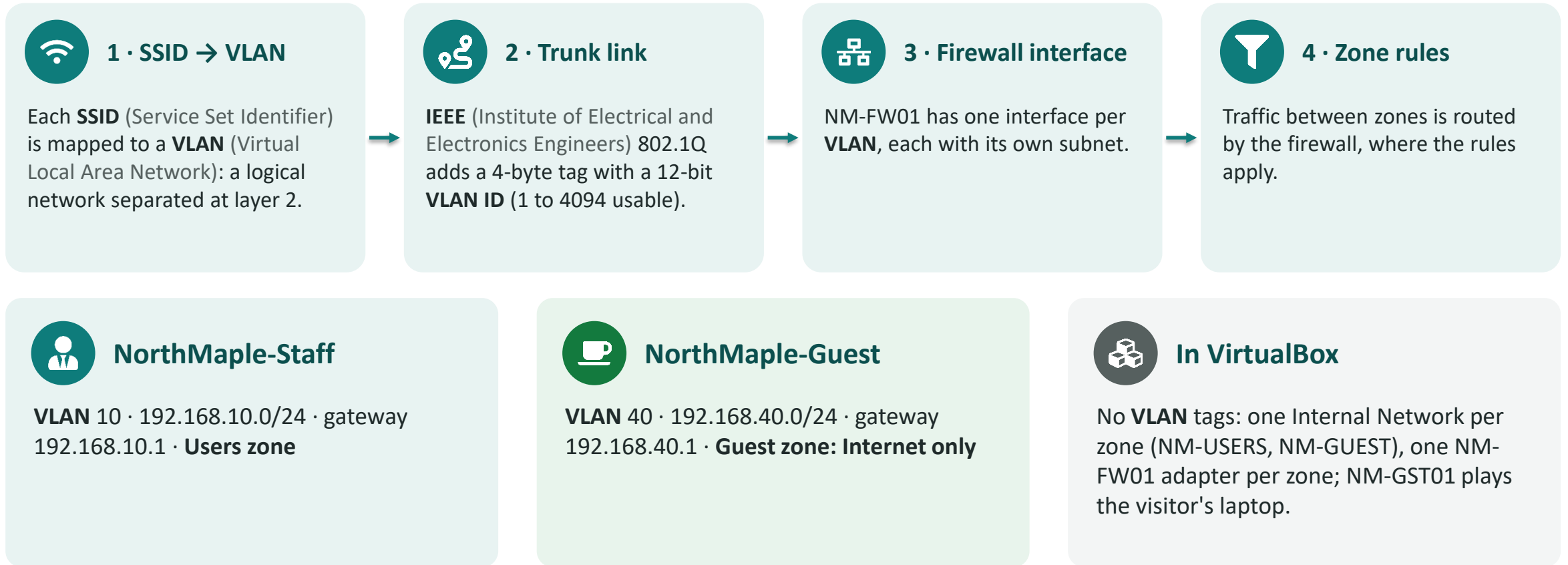
They appear in blocklists and in the first guessing rules, so their length gives little protection. With WPA3-SAE there is no offline search at all.

Cyber.SoHo - Class 13 - EFF large word list = 7,776 words (12.9 bits per word)

Figure 1.3 — Expected time to search half of the possible random passphrases at one million guesses per second (logarithmic scale). Human-chosen passphrases are not on this scale because they are guessed first. The calculator in the **HTML** (HyperText Markup Language) module and the spreadsheet `C13_Reference_Tables.xlsx` let you change the assumed speed. File: `C13_Fig1-3_Passphrase_Strength.svg` — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** module and the companion ZIP.



Guest and corporate Wi-Fi in separate zones



CCCS (Canadian Centre for Cyber Security): "ensure the settings in your **VLAN** restrict guests and devices in the guest networks from interacting with devices and information in the primary network."

Source: <https://www.cyber.gc.ca/en/guidance/guest-wi-fi-itsap80023>



GUEST firewall rules on NM-FW01

#	Action	Source	Destination	Port / protocol	Purpose
1	Pass	GUEST net	192.168.40.1 (GUEST address of NM-FW01)	TCP/UDP 53 (DNS)	Name resolution through the firewall
2	Block	GUEST net	This Firewall (self)	any	No access to the web interface or SSH of NM-FW01
3	Block	GUEST net	PRIVATE_NETS alias: 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16	any	No access to the Users, Servers and DMZ zones
4	Pass	GUEST net	any	TCP 80, 443	Web browsing on the Internet
-	Block (implicit)	any	any	any	Everything that no rule passes is blocked



First match wins

Rules are read from top to bottom; the first matching rule decides; anything no rule passes is blocked.



Rule 1 above rule 2

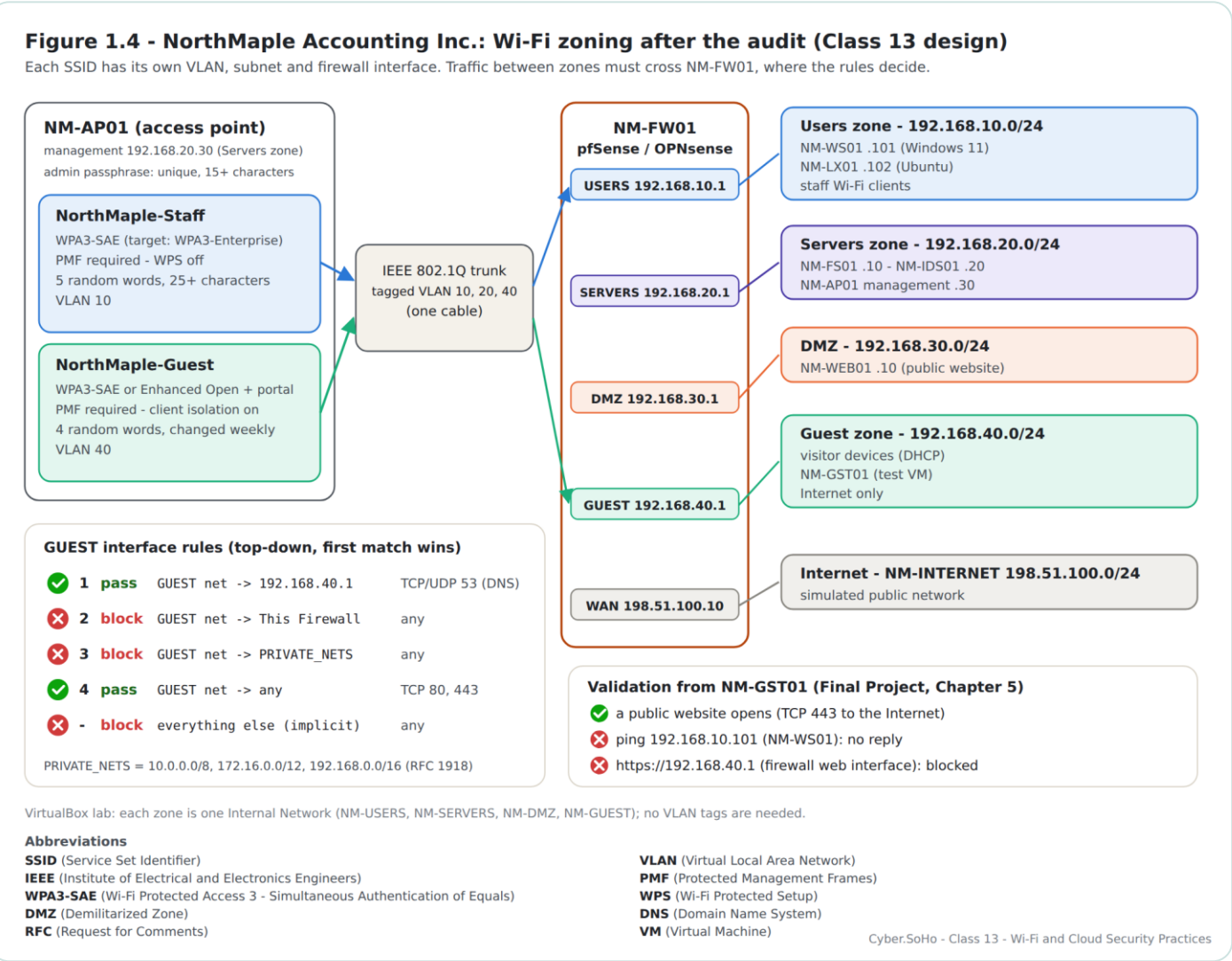
DNS (Domain Name System) queries go to the firewall's own guest address, 192.168.40.1, which rule 2 would otherwise block.



Rule 3 above rule 4

"any" in rule 4 also includes the **RFC** (Request for Comments) 1918 private ranges of the internal zones. PRIVATE_NETS is an alias created once and reused.

NorthMaple Wi-Fi zoning after the audit



How to read it

- **Complete the zone on NM-AP01:** client isolation, a captive portal with the terms of use, a bandwidth limit.
- **Prove it from NM-GST01:** ping 192.168.10.101 fails; https://192.168.40.1 fails; a public website opens. These are the Chapter 5 evidence.
- **Public Wi-Fi outside the office (scenario 6): WPA2** (Wi-Fi Protected Access 2) or **WPA3** (Wi-Fi Protected Access 3) protects only the radio link to that access point; use the **VPN** (Virtual Private Network) of LAB_06.

Figure 1.4 — NorthMaple Wi-Fi zoning after the audit: each **SSID** (Service Set Identifier) has its own **VLAN** (Virtual Local Area Network), subnet and firewall interface, and the guest zone reaches the Internet only.

File: C13_Fig1-4_NorthMaple_WiFi_Zoning.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



Lesson 1 — watch



10:54

Wireless Security Settings

Professor Messer · 10:54 min

Explains **WPA2** (Wi-Fi Protected Access 2) and **WPA3** (Wi-Fi Protected Access 3), the **SAE** (Simultaneous Authentication of Equals) handshake, pre-shared keys versus 802.1X/**RADIUS** (Remote Authentication Dial-In User Service), and why **WPA3** resists offline guessing.

<https://www.youtube.com/watch?v=KaqKoKNEKnE>



8:58

Securing Wireless and Mobile

Professor Messer · 8:58 min

Site surveys and heat maps for good coverage, plus the mobile-device management that a small office adds around its wireless network.

<https://www.youtube.com/watch?v=iAR6SgvtezY>



6:22

Password Security

Professor Messer · 6:22 min

Why length beats complexity, why passphrases work, and why a shared secret must change when someone who knows it leaves — the reasoning behind the Wi-Fi passphrase rules.

<https://www.youtube.com/watch?v=eMOe-PLBy1k>



Before opening a link: check it with the VirusTotal **URL** (Uniform Resource Locator) scanner <https://www.virustotal.com/gui/home/url> (Legal Notice §10). A link is not an endorsement. Videos on public platforms are third-party content: comments, re-uploads and edits are not verified by Cyber.SoHo, and the platform's terms apply (§12). No TikTok links are used.

The visitor Wi-Fi at the front desk

Task: audit the exported configuration of NM-AP01 and the proposed guest firewall rule, correct every weakness, and prove that the guest **SSID** (Service Set Identifier) reaches the Internet only (uses 1.2 to 1.5).



What the review finds

- The guest **SSID** is mapped to **VLAN** (Virtual Local Area Network) 10, the Users zone of the accountants' computers.
- Guest **SSID**: **WPA2-PSK** (Wi-Fi Protected Access 2 with a Pre-Shared Key) with the **TKIP** (Temporal Key Integrity Protocol) cipher; passphrase `guest1234` printed on a card at the front desk.
- Staff **SSID**: passphrase `NorthMaple2026!` and **WPS** (Wi-Fi Protected Setup) still on.
- Access point administrator password: the factory value.
- Proposed firewall rule: "pass GUEST net to any".



What the team does, in order

1. Run the audit program: 14 findings (8 high, 6 medium) saved to `C13_L1_wifi_findings.csv`.
2. Guest **SSID** to **VLAN** 40; both **SSIDs** (Service Set Identifiers) to **WPA3-SAE** (transition mode only for two old barcode scanners); **PMF** (Protected Management Frames) required; **WPS** off; client isolation for guests.
3. New passphrases from a password manager: 5 random words (staff), 4 random words (guest, changed every Monday).
4. Replace the administrator password and record it in the device registry.
5. Replace the proposed rule with the four ordered GUEST rules and test them from NM-GST01.



Deliverables: guest zone row (Chapter 1) • 4 GUEST rules and their tests (Chapter 5) • NM-AP01 registry entry • findings **CSV** (Comma-Separated Values) • justifications for scenarios 6 and 9 (Chapter 7).

Program 1 — Wi-Fi zone audit

Python 3

C13_L1_wifi_zone_audit.py

- Reads the settings of the two NorthMaple **SSIDs** (a simplified export written in the program).
- Checks mode, cipher, **PMF** (Protected Management Frames), **WPS** (Wi-Fi Protected Setup), **VLAN** (Virtual Local Area Network) and client isolation of each **SSID** (1.2 and 1.5).
- Derives the **PMK** (Pairwise Master Key) exactly as **WPA2** (Wi-Fi Protected Access 2) does, with the **SSID** as salt (1.3).
- Tests each passphrase: blocklist, context words, 15-character minimum, entropy (1.4).
- Checks the proposed guest rule and prints the four corrected rules (1.5).

Result: 14 findings — 8 HIGH, 6 MEDIUM — saved in C13_L1_wifi_findings.csv.

Run it on your own computer: `python3 C13_L1_wifi_zone_audit.py` (Windows: `py C13_L1_wifi_zone_audit.py`). Standard library only.

ACCESS POINT NM-AP01 AUDIT

issue admin password

NorthMaple-Staff

OK cipher

check mode WPA2-PSK

check PMF

issue WPS

OK VLAN 10

issue passphrase

NorthMaple-Guest

issue cipher

check mode WPA2-PSK

check PMF

OK WPS

issue VLAN -> 40

issue passphrase

PBKDF2 KEY DERIVATION

pass: guest1234

salt (SSID): NorthMaple-Guest

PMK 3d2207cfdd340b8a01c7da6b990da6d5

PASSPHRASE CHECKS

entropy 46.5 bits (only if random)

issue not in blocklist

issue no context words

issue 15+ characters

GUEST FIREWALL RULE

OK 1 DNS -> firewall

issue 2 block firewall

issue 3 block PRIVATE_NETS

OK 4 web 80/443

HIGH 8 **MEDIUM 6**

OK audit complete — CSV saved

Live visualization in the **HTML** (HyperText Markup Language) module at the last step (Start / Step / Restart buttons).



LESSON 2

Security for virtual platforms and cloud services

Real-life example 2 · Program 2 · 4 videos

2.1 Virtualization and isolation

2.2 Cloud computing in one definition

2.3 The shared responsibility model

2.4 Security groups and NSGs (Network Security Groups)

2.5 Identity management basics



LESSON 2 · 2.1 VIRTUALIZATION AND ISOLATION

Hypervisors and isolation

- **Hypervisor** (virtual machine monitor): software that creates and runs **VMs** (Virtual Machines); it divides the **CPU** (Central Processing Unit) time, memory, storage and network access of one physical computer.
- **Type 1** (bare-metal) runs on the hardware: VMware ESXi, Microsoft Hyper-V, KVM, Xen. Used by data centres and cloud providers.
- **Type 2** (hosted) runs as an application: Oracle VirtualBox 7.2.16 in our lab, VMware Workstation.
- **Isolation**: a **VM** (Virtual Machine) must not read or change the memory, disk or traffic of another **VM** or of the host.

Risks (awareness level)

- **VM escape**: guest code runs on the host; example: VENOM, **CVE-2015-3456** (Common Vulnerabilities and Exposures identifier). Patch the hypervisor; remove unused virtual devices.
- **Resource reuse**: memory or disk handed to another **VM** without being cleared.
- **VM sprawl**: forgotten **VMs**; list **VMs** in the device registry.
- **Snapshots** can hold passwords and keys: protect them.
- **Networking errors**: one wrong adapter connects a lab **VM** to a real network.

Source: <https://nvd.nist.gov/vuln/detail/CVE-2015-3456>



Keep the laboratory isolated (VirtualBox)



Internal Network — always

"The outside world is limited to other **VMs** (Virtual Machines) on the same host which connect to the same internal network." One Internal Network per zone.



Bridged — never

Bridged networking "connects to one of your installed network cards and exchanges network packets directly": the **VM** (Virtual Machine) joins a real network.



Host-only and NAT

Host-only adapters are not used by the course **VM** plan. **NAT** (Network Address Translation) adapters are set to "Not attached" in Phase B.



Also on every lab VM

Keep VirtualBox updated · leave the shared clipboard, drag-and-drop and shared folders **disabled** on **VMs** that handle untrusted content · take snapshots before each lab · reference: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-125, Guide to Security for Full Virtualization Technologies.



Legal Notice §3: snapshots and isolated virtual networks keep a mistake inside your laboratory. A lab **VM** on a real network is outside the permitted scope.

Sources: <https://docs.oracle.com/en/virtualization/virtualbox/7.2/user/networkingdetails.html> · <https://csrc.nist.gov/pubs/sp/800/125/final>



Cloud computing in one definition

Cloud computing, as defined by **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-145: a model for on-demand network access to a shared pool of configurable computing resources that can be provisioned and released rapidly, with minimal management effort.



5 essential characteristics

- On-demand self-service
- Broad network access
- Resource pooling (**multi-tenancy**)
- Rapid elasticity
- Measured service



3 service models

- **IaaS** (Infrastructure as a Service): rent **VMs** (Virtual Machines), storage, networks (**EC2** (Elastic Compute Cloud), Azure **VM** (Virtual Machine))
- **PaaS** (Platform as a Service): deploy your code on a platform the provider operates
- **SaaS** (Software as a Service): use a finished application, e.g. web e-mail



4 deployment models

- Private
- Community
- Public
- Hybrid

The **CCCS** (Canadian Centre for Cyber Security) describes the same models for Canadian organizations (ITSAP.50.111).

Behind every **IaaS** offer run Type 1 hypervisors. NorthMaple's **VM** may share a physical server with another company's **VM**: **isolating tenants is the provider's job; configuring inside the tenant is the customer's job.**

Sources: <https://csrc.nist.gov/pubs/sp/800/145/final> · <https://www.cyber.gc.ca/en/guidance/models-cloud-computing-itsap50111>



The shared responsibility model



Security OF the cloud — provider

- **AWS** (Amazon Web Services): "the hardware, software, networking, and facilities that run **AWS** Cloud services".
- Microsoft: physical security, physical network, physical hosts, the hypervisor, and the platform services in **PaaS** (Platform as a Service) and **SaaS** (Software as a Service).



Security IN the cloud — customer

- The guest operating system, its updates and security patches; the applications you install.
- The security group (the **AWS**-provided firewall) configuration; **IAM** (Identity and Access Management) permissions.
- Your data, its classification and encryption options.

Always the customer's, "regardless of the type of deployment" (Microsoft): data · endpoints (the devices that connect) · accounts · access management, including **RBAC** (Role-Based Access Control), multifactor authentication and conditional access policies.



The more the provider manages (IaaS (Infrastructure as a Service) → PaaS → SaaS), the fewer layers you secure — but data, identities and access settings always remain yours.

Sources: <https://aws.amazon.com/compliance/shared-responsibility-model/> · <https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

Who secures what: the shared responsibility model

Figure 2.1 - Who secures what: the shared responsibility model

Adapted from the AWS and Microsoft descriptions. Data, devices, identities and access management always stay with the customer.

	On-premises (the VirtualBox lab)	IaaS (EC2 or Azure VM)	PaaS (provider runs the platform)	SaaS (finished application)
Information and data	Customer	Customer	Customer	Customer
Devices (endpoints)	Customer	Customer	Customer	Customer
Accounts and identities	Customer	Customer	Customer	Customer
Access management (MFA, roles)	Customer	Customer	Customer	Customer
Identity and directory infrastructure	Customer	Customer	Shared	Shared
Applications	Customer	Customer	Shared	Shared
Network controls (firewall rules)	Customer	Customer	Shared	Provider
Operating system	Customer	Customer	Provider	Provider
Hypervisor (virtualization layer)	Customer	Provider	Provider	Provider
Physical hosts	Customer	Provider	Provider	Provider
Physical network	Customer	Provider	Provider	Provider
Physical datacenter	Customer	Provider	Provider	Provider

Customer Shared Provider

Red frame: the IaaS model used by NM-WEB01 in the cloud

Sources: <https://aws.amazon.com/compliance/shared-responsibility-model/>
and <https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

Abbreviations

IaaS (Infrastructure as a Service)
MFA (Multi-Factor Authentication)

PaaS (Platform as a Service)
EC2 (Elastic Compute Cloud)

SaaS (Software as a Service)
VM (Virtual Machine)

Cyber.SoHo - Class 13 - Wi-Fi and Cloud Security Practices

How to read it

- Rows are the layers of a system; columns are the service models.
- The **top four rows** stay with the customer in every column.
- Moving right (**IaaS** (Infrastructure as a Service) → **PaaS** (Platform as a Service) → **SaaS** (Software as a Service)), more layers move to the provider.
- The **red frame** is **IaaS**: the model used by NM-WEB01 in a free-tier cloud account.

Figure 2.1 — The shared responsibility model by service model. Data, devices, identities and access management always remain the customer's responsibility.

File: C13_Fig2-1_Shared_Responsibility.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



Case study: Capital One, 2019

≈ 6 million

individuals in Canada affected (March 22–23, 2019)

≈ 1 million

Social Insurance Numbers of Canadian credit card customers

30+

entities whose data the attacker downloaded (U.S. Department of Justice)



What happened

- The person convicted on June 17, 2022 "used a tool she built to scan Amazon Web Services accounts to look for misconfigured accounts" (DOJ).
- The **OPC** (Office of the Privacy Commissioner of Canada) opened an investigation on July 31, 2019.
- **The provider's infrastructure was not the weak point: the configuration of customer accounts was.**



Accountability stays with you

- **PIPEDA** (Personal Information Protection and Electronic Documents Act): an organization remains accountable for personal information it transfers to a third party for processing.
- **Québec Law 25**: adds obligations such as reporting confidentiality incidents to the **CAI** (Commission d'accès à l'information du Québec).
- Moving data to a provider does not move this accountability.

Sources: <https://support.capitalone.ca/cyber/facts2019> · https://www.priv.gc.ca/en/opc-news/news-and-announcements/2019/an_190731_02/ · <https://www.justice.gov/usao-wdwa/pr/former-seattle-tech-worker-convicted-wire-fraud-and-computer-intrusions>



Security groups, network ACLs and NSGs



AWS security group

- An **AWS** (Amazon Web Services) security group is attached to a resource, such as an **EC2** (Elastic Compute Cloud) instance.
- **Stateful**: the response to an allowed connection is allowed automatically.
- **Allow rules only** — "you can specify allow rules, but not deny rules".
- New group: no inbound rule; all outbound allowed.
- Several groups on one resource: rules are **aggregated**.



AWS network ACL

- Works at the **subnet** level.
- **Stateless**: return traffic "must be explicitly allowed".
- Allow **and** deny rules.
- Rules evaluated in ascending order until one matches.



Azure NSG

- An **NSG** (Network Security Group) is attached to a subnet, a network interface, or both; **stateful**.
- Allow and deny; priority **100 to 4096**, lowest number first.
- "Once traffic matches a rule, processing stops."
- Default rules that cannot be deleted: 65000, 65001 and **65500 DenyAllInbound**.

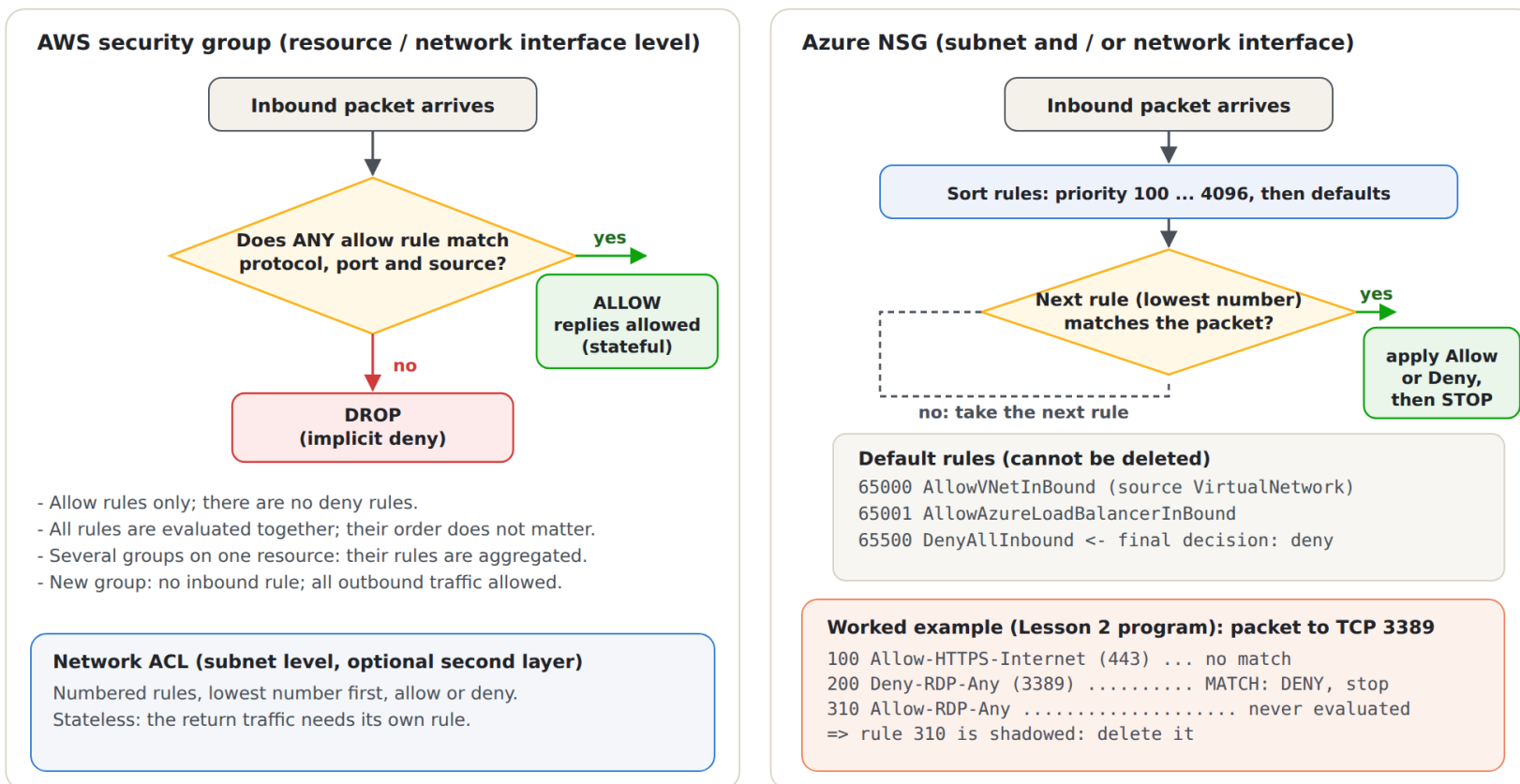
Every rule uses the same fields: protocol · destination port or range · source address in **CIDR** (Classless Inter-Domain Routing) notation · and, in Azure, action and priority.

Sources: <https://docs.aws.amazon.com/vpc/latest/userguide/security-group-rules.html> · <https://docs.aws.amazon.com/vpc/latest/userguide/infrastructure-security.html> · <https://learn.microsoft.com/en-us/azure/virtual-network/network-security-groups-overview>



How the cloud filters decide on an inbound packet

Figure 2.2 - How the cloud filters decide on an inbound packet



Abbreviations

AWS (Amazon Web Services)
TCP (Transmission Control Protocol)

NSG (Network Security Group)
VNet (Virtual Network)

ACL (Access Control List)
RDP (Remote Desktop Protocol)

Cyber.SoHo - Class 13 - Wi-Fi and Cloud Security Practices

How to read it

- **AWS** (Amazon Web Services): all allow rules are checked together; no match means the packet is dropped.
- **Azure**: rules are sorted by priority; the first match decides, then processing stops.
- **Shadowed rule**: Allow-RDP-Any (310) is never reached, because Deny-RDP-Any (200) matches first. Delete it.

Figure 2.2 — How an **AWS** security group and an Azure network security group decide on an inbound packet, with the shadowed-rule example from the Lesson 2 program.

File: C13_Fig2-2_SG_vs_NSG_Decision.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



NM-WEB01 inbound rules with least privilege

#

CIDR in one minute

CIDR (Classless Inter-Domain Routing) notation writes an address range as address/prefix length.

- `0.0.0.0/0` = every **IPv4** (Internet Protocol version 4) address
- `::/0` = every **IPv6** (Internet Protocol version 6) address
- `10.0.1.0/24` = 256 addresses, 10.0.1.0 to 10.0.1.255
- `203.0.113.25/32` = exactly one address

`10.0.1.0/24` is the example administration subnet inside your own cloud network, reached through the **VPN** (Virtual Private Network).

Port	Source	Decision	Why
TCP 443 (HTTPS)	0.0.0.0/0	Allow	The public website must be reachable by everyone
TCP 80 (HTTP)	0.0.0.0/0	Allow	Only to redirect visitors to HTTPS (Lesson 3)
TCP 22 (SSH)	10.0.1.0/24	Allow	Administration through the VPN only
TCP 3389 (RDP)	—	No rule	A Linux web server has no reason to accept RDP
TCP 3306 (MySQL)	—	No rule	Only the application may reach the database
UDP 51820	0.0.0.0/0	Allow (VPN endpoint)	WireGuard for remote workers (LAB_06)

Never SSH (Secure Shell) **from 0.0.0.0/0 (resilience scenario 2)**: automated scanning of the whole **IPv4** address space never stops, so an open **SSH** port receives login attempts from unknown sources soon after it opens.

UDP (User Datagram Protocol) **51820 may stay open**: WireGuard does not answer packets that are not authenticated with a valid key, so this open port reveals very little.



Identity management basics (1/2): identities and AWS IAM



Identification

the claim of an identity
(a user name)



Authentication

the proof (password,
key, **MFA** (Multi-Factor
Authentication) code,
certificate)



Authorization

what the identity may
do



Accounting

the record of what it did
(logs)



AWS IAM

- In **AWS** (Amazon Web Services) **IAM** (Identity and Access Management), the **root user** has complete access to every service. Use it only for the tasks that require it, protect it with **MFA**, create no access keys for it.
- Daily work uses **IAM users** (long-term credentials), **groups**, and **IAM roles**, which give temporary credentials to a person or a program, such as the code on NM-WEB01.
- **Policies** are **JSON** (JavaScript Object Notation) documents: `Effect` (Allow/Deny), `Action`, `Resource` (an **ARN** (Amazon Resource Name)), optional conditions.

Least-privilege policy for the role of NM-WEB01

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "s3:GetObject",
    "Resource":
      "arn:aws:s3:::northmaple-site-assets/*"
  }]
}
```

One action, one bucket. It replaces `s3:*` on `*` (every storage action on every bucket).

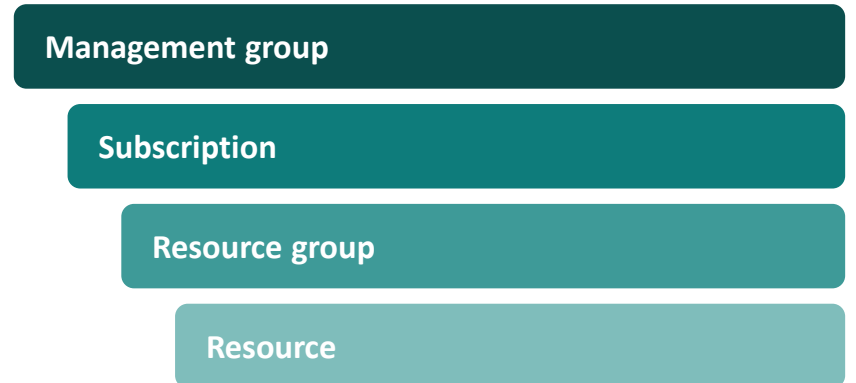
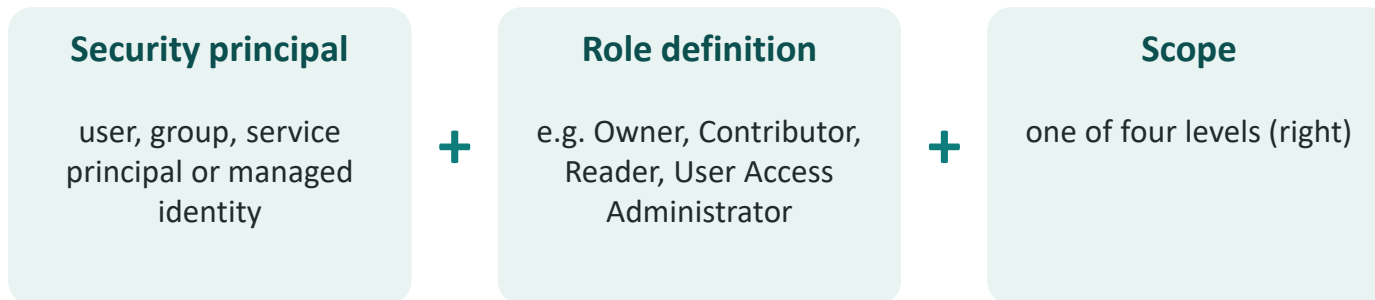
Sources: <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html> · <https://docs.aws.amazon.com/IAM/latest/UserGuide/root-user-best-practices.html>



Identity management basics (2/2): Microsoft Azure

Microsoft Entra ID (named Azure Active Directory until 2023): "a cloud-based identity and access management service that provides authentication, policy enforcement, and protection for users, devices, apps, and resources".

An Azure RBAC (Role-Based Access Control) **role assignment** has three elements



Azure **RBAC** is additive; deny assignments, when present, are evaluated first.

A role assigned at a higher level applies to everything below it.



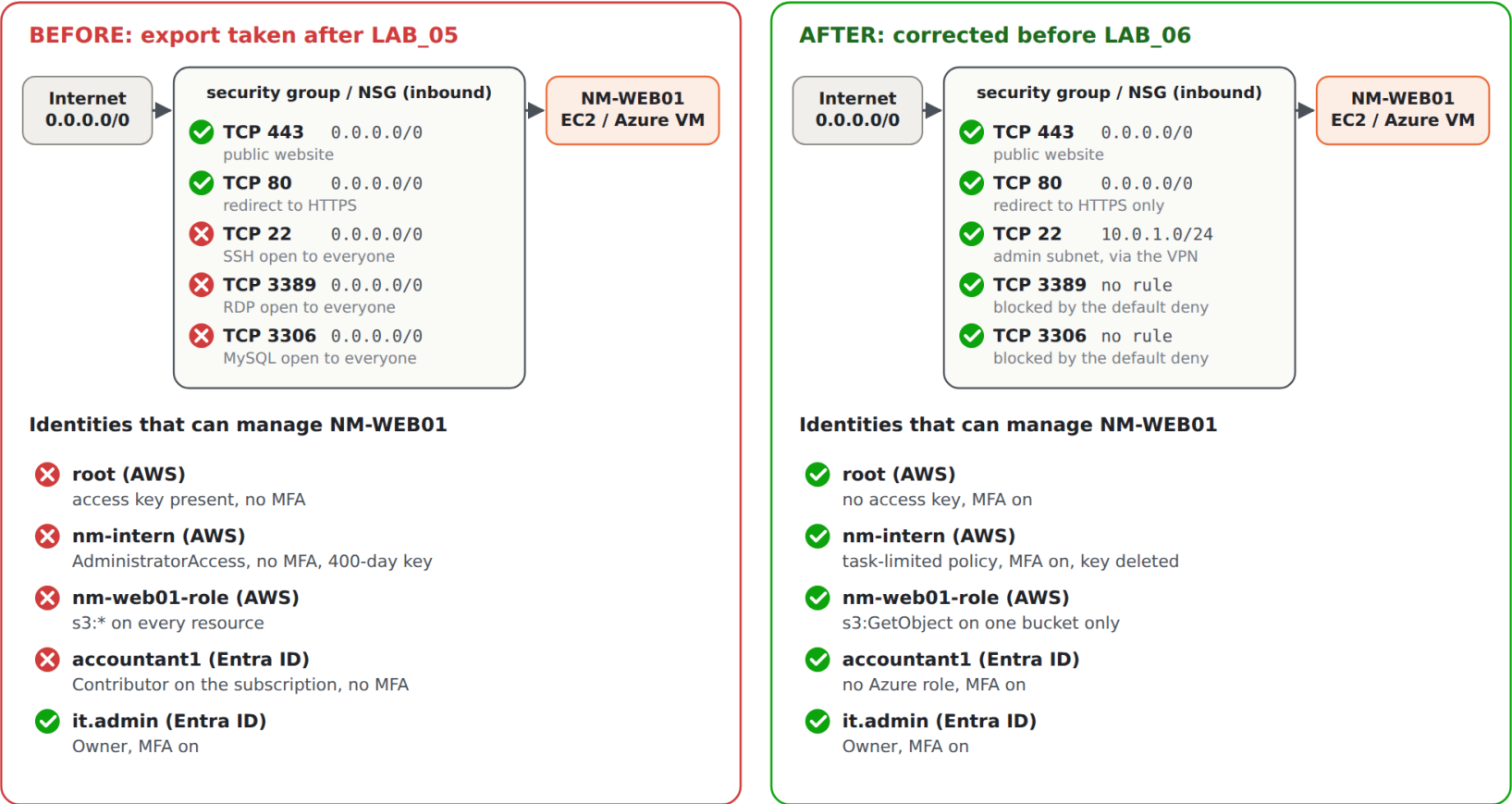
Least privilege has two dimensions in the cloud

The **smallest set of actions** (Reader instead of Contributor; `s3:GetObject` instead of `s3:*`) on the **smallest scope** (one resource group or one bucket, not the whole subscription or `*`).

Sources: <https://learn.microsoft.com/en-us/entra/fundamentals/whatis> · <https://learn.microsoft.com/en-us/azure/role-based-access-control/overview>

NM-WEB01 in the cloud: exposure before and after

Figure 2.3 - NM-WEB01 in the cloud: exposure before and after the review



Every item above is security IN the cloud, a customer responsibility. The provider secures the facilities, the hosts and the hypervisor.

How to read it

- **Before:** SSH (Secure Shell), RDP (Remote Desktop Protocol) and MySQL open to 0.0.0.0/0; four identities with excessive rights or no MFA (Multi-Factor Authentication).
- **After:** SSH only from the VPN (Virtual Private Network) subnet; 3389 and 3306 blocked by the default deny; MFA and least privilege on every identity.
- Every item is **security IN the cloud:** the customer's side.

Figure 2.3 — NM-WEB01 inbound rules and identities, before and after the review. Every item is a customer responsibility (security in the cloud).
File: C13_Fig2-3_NM-WEB01_Exposure.svg — SVG (Scalable Vector Graphics) and PNG (Portable Network Graphics) in the HTML (HyperText Markup Language) module and the companion ZIP.



Lesson 2 — watch



Cloud Infrastructures

Professor Messer · 9:56 min

The responsibility matrix that shows who secures what across **SaaS** (Software as a Service), **PaaS** (Platform as a Service) and **IaaS** (Infrastructure as a Service), plus the building blocks of a cloud deployment.

<https://www.youtube.com/watch?v=8gpQ8Q6xxiU>



Virtualization Vulnerabilities

Professor Messer · 5:29 min

VM (Virtual Machine) escape (jumping between virtual machines on one hypervisor) and resource reuse — the isolation risks that a hypervisor must prevent.

<https://www.youtube.com/watch?v=t2JrPrzRDLA>



Identity and Access Management

Professor Messer · 12:46 min

Provisioning accounts, authentication, single sign-on and federation — the identity concepts that **AWS** (Amazon Web Services) **IAM** (Identity and Access Management) and Microsoft Entra ID put into practice.

<https://www.youtube.com/watch?v=ZoOyYqhptik>



Access Controls

Professor Messer · 7:49 min

Least privilege and the main access-control models (**MAC** (Media Access Control), DAC, **RBAC** (Role-Based Access Control), ABAC) — the same least-privilege idea applied to cloud permissions and scopes.

<https://www.youtube.com/watch?v=9ANHcZwJfdQ>



Before opening a link: check it with the VirusTotal **URL** (Uniform Resource Locator) scanner <https://www.virustotal.com/gui/home/url> (Legal Notice §10). A link is not an endorsement. Videos on public platforms are third-party content: comments, re-uploads and edits are not verified by Cyber.SoHo, and the platform's terms apply (§12). No TikTok links are used.

NorthMaple's website in a free-tier cloud account

Task: review the inbound rules of NM-WEB01 in **AWS** (Amazon Web Services) and Azure and the identities that manage it; find every rule or permission that breaks least privilege; place each finding on the correct side of the shared responsibility model (2.3 to 2.5).



What the review finds

- **SSH** (Secure Shell), **RDP** (Remote Desktop Protocol) and MySQL open to 0.0.0.0/0 in the **AWS** security group.
- An Azure **NSG** (Network Security Group) rule allowing **SSH** from any source.
- An access key created for the **AWS** root user.
- The intern account holds AdministratorAccess; the web server role has `s3: *` on `*`.
- An accountant is Contributor on the whole Azure subscription.



What the team does, in order

1. Run the PowerShell review: 12 findings (1 critical, 10 high, 1 medium), all on the customer side.
2. Delete the 3389 and 3306 rules; **SSH** only from the administration subnet behind the **VPN** (Virtual Private Network); remove the shadowed Azure rule.
3. Delete the root access key; **MFA** (Multi-Factor Authentication) for root, intern and accountant; task-limited policy; one-bucket role policy.
4. Remove the accountant's Contributor role; record every identity with role, scope and **MFA** status.
5. VirtualBox users: check that every **VM** (Virtual Machine) uses only Internal Network adapters.



Cloud option (Legal Notice §3): respect the acceptable-use policy of **AWS** or Azure and watch the free-tier limits; all cloud costs, overage charges and account consequences are your responsibility.

Program 2 — Cloud access review

PowerShell

C13_L2_cloud_access_review.ps1

- Reads three **JSON** (JavaScript Object Notation) exports: the **AWS** (Amazon Web Services) security group, the Azure **NSG** (Network Security Group) and the identity inventory.
- **AWS**: examines every allow rule; the order does not matter (2.4).
- Azure: sorts rules by priority and simulates one Internet packet per port; the first match decides (2.4).
- Identities: six least-privilege checks — root key, **MFA** (Multi-Factor Authentication), AdministratorAccess, key age over 90 days, `s3:*` on `*`, Contributor on a subscription (2.5).
- Prints the corrected inbound rules for the manual.

Result: 12 findings — 1 CRITICAL, 10 HIGH, 1 MEDIUM — all "security IN the cloud", saved in `C13_L2_cloud_findings.csv`.

Run: `powershell -ExecutionPolicy Bypass -File .\C13_L2_cloud_access_review.ps1` Or `pwsh ./C13_L2_cloud_access_review.ps1` with the three **JSON** files in the same folder.

NM-WEB01 CLOUD REVIEW

AWS security group (all rules)

OK	TCP 443	public web
OK	TCP 80	redirect
issue	TCP 22	SSH
issue	TCP 3389	RDP
issue	TCP 3306	MySQL

Azure NSG (priority order)

issue	port 22
OK	port 443
OK	port 3306
OK	port 3389

Identities

issue	root
issue	nm-intern
issue	nm-web01-role
OK	it.admin
issue	accountant1

CRITICAL 1 **HIGH 10** **MED 1**

OK corrected rules ready for LAB_06

Live visualization in the **HTML** (HyperText Markup Language) module at the last step (Start / Step / Restart buttons).



LESSON 3

Web application and service security

Real-life example 3 · Program 3 · 4 videos

3.1 How a web application processes a request

3.2 The **OWASP** (Open Worldwide Application Security Project) Top 10:2025

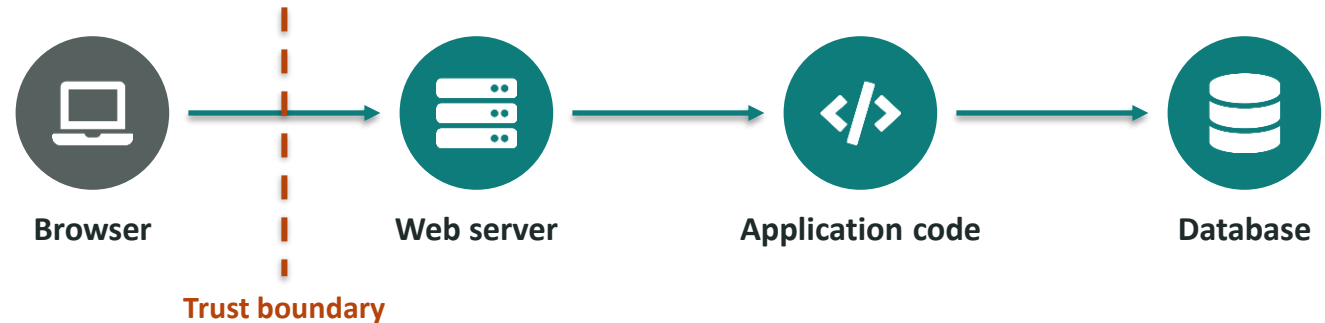
3.3 **SQL** (Structured Query Language) injection

3.4 Cross-site scripting

3.5 Securing the service before LAB_06

LESSON 3 · 3.1 REQUESTS, RESPONSES AND TRUST

How a web application processes a request



- **Request:** a method (GET to read, POST to submit), a path such as `/invoices?code=NM-C-217`, headers (including cookies) and sometimes a body (form fields).
- **Response:** a status code (200 OK, 301 redirect, 404 not found), headers and a body, usually an **HTML** (HyperText Markup Language) page. A **web service** or **API** (Application Programming Interface) returns data, often **JSON** (JavaScript Object Notation).
- **Every byte from the client is untrusted input:** **URL** (Uniform Resource Locator) parameters, form fields, cookies, headers, uploaded files. Browser-side checks do not protect the server.
- **HTTPS** (Hypertext Transfer Protocol Secure) = **HTTP** (Hypertext Transfer Protocol) inside **TLS** (Transport Layer Security): it protects data in transit and authenticates the server; it does not correct a flaw in the application.



The OWASP Top 10:2025 at an awareness level

Code	Category	NorthMaple example	Main defense
A01:2025	Broken Access Control	Changing invoice=1002 to invoice=1003 shows another client's invoice	Deny by default; check ownership of every object on the server
A02:2025	Security Misconfiguration	Directory listing on, default page, detailed error pages	Hardened baseline; remove defaults; security headers
A03:2025	Software Supply Chain Failures	An outdated JavaScript library on the portal page	Inventory of components; updates from trusted sources
A04:2025	Cryptographic Failures	Portal served over plain HTTP	HTTPS everywhere; salted password hashing (Class 14)
A05:2025	Injection	The invoice lookup of real-life example 3	Parameterized queries; output encoding; allow-list validation
A06:2025	Insecure Design	No limit on lookups, so client codes can be tried one after another	Threat modelling; rate limits designed in
A07:2025	Authentication Failures	The portal administration page accepts unlimited password attempts	MFA; blocklists; rate limiting
A08:2025	Software or Data Integrity Failures	An update installed from an unverified download	Signed updates; hash verification
A09:2025	Security Logging and Alerting Failures	No alert when 500 lookups arrive in one minute	Log security events; alert (IDS, central logs)
A10:2025	Mishandling of Exceptional Conditions	A database error prints the full SQL query to the visitor	Fail closed; generic error pages; handle every error

MITRE 2025 CWE (Common Weakness Enumeration) Top 25: #1 CWE-79 cross-site scripting, #2 CWE-89 SQL injection. **Abbreviations:** **OWASP** (Open Worldwide Application Security Project); **HTTP** (Hypertext Transfer Protocol); **HTTPS** (Hypertext Transfer Protocol Secure); **MFA** (Multi-Factor Authentication); **IDS** (Intrusion Detection System); **SQL** (Structured Query Language)

Sources: <https://top10.owasp.org/2025/> · https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html



Five categories that matter most for a small firm

A01

Broken access control — The server does not check that the logged-in user owns the object. Changing `invoice=1002` to `invoice=1003` shows another client's invoice (**IDOR**). Check on the server, for every request. Now includes **SSRF** (Server-Side Request Forgery).

A02

Security misconfiguration — Default accounts, directory listing, detailed error pages, missing security headers.

A05

Injection — Untrusted input reaches an interpreter (database, browser, command shell) and is executed as a command. Includes **SQL** (Structured Query Language) injection and cross-site scripting.

A07

Authentication failures — No **MFA** (Multi-Factor Authentication), weak password rules, no protection against credential stuffing (passwords leaked from another site tried automatically).

A09

Security logging and alerting failures — If nothing is logged, an attack cannot be detected or investigated: the **IDS** (Intrusion Detection System) of LAB_04 and the logs of NM-WEB01.

Sources: <https://top10.owasp.org/2025/> · <https://www.cyber.gc.ca/en/guidance/strategies-protecting-web-application-systems-against-credential-stuffing-attacks>



SQL injection: when data becomes code

The flaw

- The application builds the **SQL** (Structured Query Language) command by **concatenating** user input into its text.
- The database parser receives one string and cannot tell the developer's characters from the user's.
- A quote in the input ends the text value early; what follows is parsed as **SQL** syntax. An always-true condition then returns **every** client's invoices.
- The input changed the **structure** of the command, not only its value.

Defense in layers

1. **Parameterized query** (prepared statement): the first defense of the **OWASP** (Open Worldwide Application Security Project) cheat sheet.
 2. **Allow-list validation**: a client code must match NM-C-### and nothing else.
 3. **Read-only database account** on the invoice table.
 4. **Generic error messages**: never show the **SQL** text.
- A **WAF** (Web Application Firewall) and the **IDS** (Intrusion Detection System) signatures of Class 8 detect attempts; **the fix is in the code**.



Not a historical problem: from May 27, 2023, the CL0P ransomware group exploited an **SQL** injection zero-day in MOVEit Transfer (**CVE-2023-34362** (Common Vulnerabilities and Exposures identifier), **CISA** (Cybersecurity and Infrastructure Security Agency) advisory AA23-158A). **CISA** and the **FBI** (Federal Bureau of Investigation) then asked software makers to eliminate this class of flaw by design.

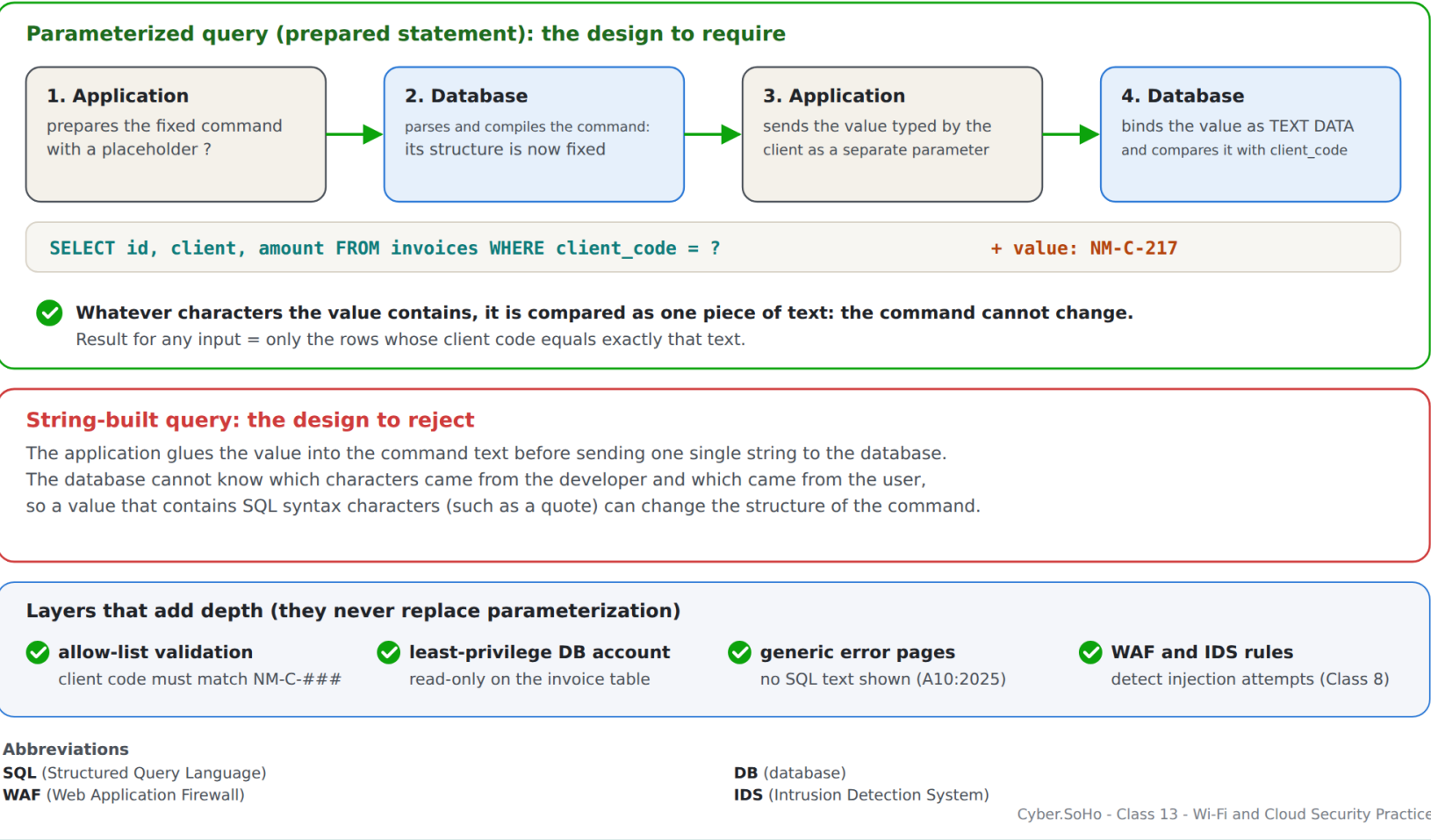
Sources: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html · <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>



How a parameterized query keeps command and data apart

Figure 3.1 - How a parameterized query keeps the command and the data apart

NorthMaple invoice lookup. The safe version sends the command and the value in two separate steps, so the value can never be read as SQL syntax.



How to read it

- The database **parses the command first**, with a placeholder ?.
- The value arrives **afterwards** and is bound as text data.
- Its characters never pass through the **SQL** (Structured Query Language) parser, so they cannot change the command.
- In Program 3 the malicious input matches **0 rows**.

Figure 3.1 — A parameterized query sends the command and the value in two steps, so a value that contains **SQL** syntax can never change the command.

File: C13_Fig3-1_Parameterized_Query.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



Cross-site scripting: when data becomes script

Cross-site scripting (XSS): the application inserts untrusted data into its **HTML** (HyperText Markup Language) without encoding it; the browser runs it as code with the permissions of the site: it can read the page, send requests as the user, and read cookies not marked HttpOnly.



Stored XSS

Saved on the server (a note in the portal's message box) and delivered to everyone who views it.



Reflected XSS

Comes from the request itself, such as a search term in the **URL** (Uniform Resource Locator), and is echoed in the response.



DOM-based XSS

The page's own JavaScript writes untrusted data into the page on the client side.



Output encoding

Replace characters with a meaning in **HTML**: `< → <; > → >;`. It depends on the context; prefer templates that encode automatically.



Content-Security-Policy

A response header that limits the sources from which scripts may run.



HttpOnly cookie

A session cookie with the HttpOnly attribute cannot be read by scripts.

Source: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html



Harden the service before LAB_06

Header or setting	Recommended value
Strict-Transport-Security	max-age=63072000; includeSubDomains
Content-Security-Policy	default-src 'self' (adapt to the site)
X-Content-Type-Options	nosniff
X-Frame-Options	DENY (or CSP frame-ancestors 'none')
Referrer-Policy	strict-origin-when-cross-origin
Server	No version number (Apache: ServerTokens Prod)
X-XSS-Protection	Not sent, or 0
Set-Cookie (session)	Secure; HttpOnly; SameSite=Lax
Port 80 (HTTP)	301 redirect to https://

Full checklist with "what it does" and the LAB_06 check: Table 3.2 in the **HTML** (HyperText Markup Language) module and C13_T3-2_HTTP_Security-Headers_Checklist.csv.



HTTPS only, safe cookies

- Port 80 answers every request with a **301** redirect to **HTTPS** (Hypertext Transfer Protocol Secure).
- **HSTS** (HTTP Strict Transport Security): the browser uses only **HTTPS** for this host for max-age = 63,072,000 s = **730 days**.
- Session cookie: **Secure** (**HTTPS** only), **HttpOnly** (unreadable by scripts), **SameSite=Lax** (reduces **CSRF** (Cross-Site Request Forgery)).



Website guidance

The **CCCS** (Canadian Centre for Cyber Security) asks owners to require **HTTPS** (**TLS** (Transport Layer Security) 1.3 recommended), add a **WAF** (Web Application Firewall), separate administrator log-in, keep tested backups, monitor, and isolate web-facing applications (NorthMaple's **DMZ** (Demilitarized Zone)).

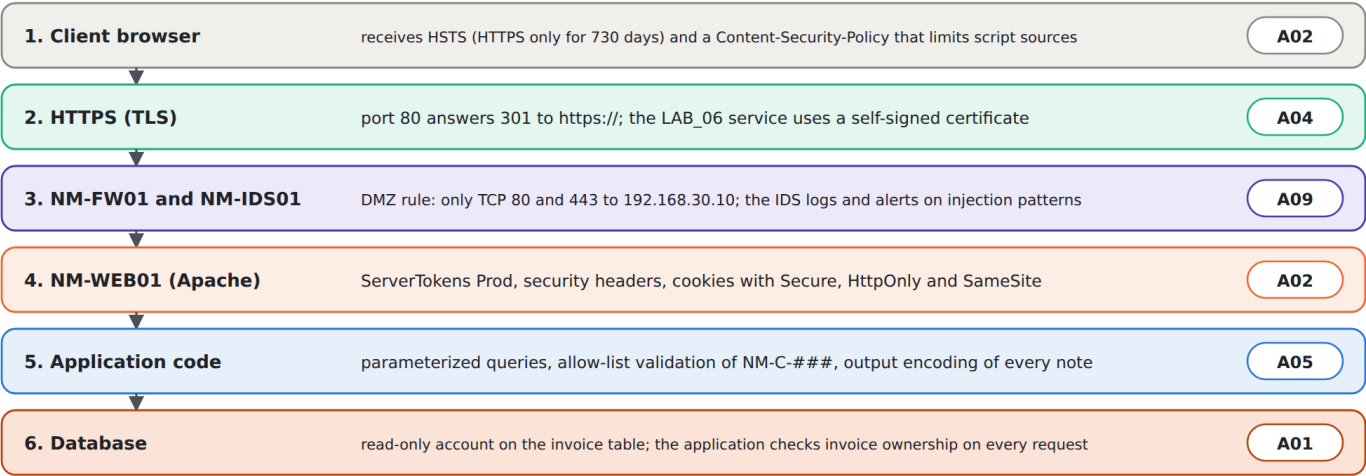
Sources: <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html> · <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security> · <https://www.cyber.gc.ca/en/guidance/security-considerations-your-website-itsm60005>



Defense layers for the NorthMaple client portal

Figure 3.2 - Defense layers for the NorthMaple client portal (after LAB_06)

A request from a client crosses six layers, from top to bottom. Each layer answers one OWASP Top 10:2025 category.



Evidence produced by the Lesson 3 program

- ❌ Before hardening: 10 checks, 7 FAIL (injection demonstration, 5 missing headers, cookie flags) and 1 WARN (server version)
- ✅ Parameterized query: 0 rows for the malicious input. Output encoding: the stored script is displayed as text
- ✅ After LAB_06: capture the headers with `curl -skI https://192.168.30.10/ > headers.txt`, then run the program on headers.txt
- ✅ Expected after hardening: every header and cookie check PASS; only the deliberate part A demonstration stays FAIL

Final Project, Chapter 7, scenario 3: the public web server in the DMZ is compromised

Parameterized queries, output encoding, security headers and the DMZ rules limit what an attacker can reach from NM-WEB01.

Abbreviations

HSTS (HTTP Strict Transport Security)
TLS (Transport Layer Security)
IDS (Intrusion Detection System)

HTTPS (Hypertext Transfer Protocol Secure)
DMZ (Demilitarized Zone)
OWASP (Open Worldwide Application Security Project)

Cyber.SoHo - Class 13 - Wi-Fi and Cloud Security Practices

How to read it

- A request crosses **six layers**, from the browser to the database.
- Each layer answers one **OWASP** (Open Worldwide Application Security Project) Top 10:2025 category (A01, A02, A04, A05, A09).
- No single layer is enough: the code (parameterized queries, encoding) and the configuration (headers, **DMZ** (Demilitarized Zone) rules) work together.
- Final Project, Chapter 7, scenario 3: the public web server is compromised.

Figure 3.2 — The defense layers a request crosses in the NorthMaple client portal, and the **OWASP** Top 10:2025 category each one answers.

File: C13_Fig3-2_Portal_Defense_Layers.svg — **SVG** (Scalable Vector Graphics) and **PNG** (Portable Network Graphics) in the **HTML** (HyperText Markup Language) module and the companion ZIP.



Lesson 3 — watch



SQL (Structured Query Language) Injection

Professor Messer · 5:09 min

How untrusted input concatenated into a query changes the command and exposes a database — exactly the flaw in real-life example 3.

<https://www.youtube.com/watch?v=qFUOLkEk8AQ>



Cross-site Scripting (XSS)

Professor Messer · 8:34 min

How injected script runs in a visitor's browser (stored, reflected and DOM-based), and why every output must be encoded.

<https://www.youtube.com/watch?v=PKgw0CLZlHc>



Application Security

Professor Messer · 8:26 min

Input validation, secure cookies, code signing and sandboxing — the developer-side defenses that harden a web application.

<https://www.youtube.com/watch?v=fFvXv3WkLpA>



Misconfiguration Vulnerabilities

Professor Messer · 7:09 min

Open cloud storage, default passwords, insecure protocols and needless open ports — the A02:2025 Security Misconfiguration category in practice.

<https://www.youtube.com/watch?v=NBKzIUqzVmE>



Before opening a link: check it with the VirusTotal **URL** (Uniform Resource Locator) scanner <https://www.virustotal.com/gui/home/url> (Legal Notice §10). A link is not an endorsement. Videos on public platforms are third-party content: comments, re-uploads and edits are not verified by Cyber.SoHo, and the platform's terms apply (§12). No TikTok links are used.

The client portal's invoice lookup before HTTPS

Task: on a local copy of the new invoice lookup page, prove the **SQL** (Structured Query Language) injection flaw and its fix, prove that output encoding neutralizes a stored script, check the security headers, and record the evidence that LAB_06 completes once **HTTPS** (Hypertext Transfer Protocol Secure) is enabled (3.3 to 3.5).



What the review finds

- The **SQL** query of the lookup is built by string concatenation.
- Client notes are displayed as raw **HTML** (HyperText Markup Language).
- Apache still has its default settings: 5 required headers missing; the Server header shows `Apache/2.4.58 (Ubuntu)`.
- The session cookie has no Secure, HttpOnly or SameSite attribute.



What the team does, in order

1. Run the program: the string-built query returns all 3 invoices (FAIL); the parameterized query returns 0 rows (PASS).
2. A stored note with a script element is shown as text after `html.escape()` (PASS).
3. The technician parameterizes the query, encodes notes, adds the headers and cookie attributes.
4. In LAB_06 (your own lab only): `curl -sI http://192.168.30.10/` shows 301; `curl -skI https://192.168.30.10/ > headers.txt`, then run the program on `headers.txt`.



—k accepts only the self-signed certificate of your LAB_06 service — never against a production site. If you ever find a real vulnerability, report it to the owner and to the instructor; do not exploit or publish it (Legal Notice §11).

Program 3 — Web input safety

Python 3

C13_L3_web_input_safety.py

- Creates an in-memory SQLite database with three fictional invoices; nothing leaves your computer.
- Part A: the unsafe, string-built lookup (3.3).
- Part B: the same lookup as a parameterized query (3.3).
- Part C: a stored note before and after **HTML** encoding (3.4).
- Part D: five security headers, the Server banner and the cookie attributes (3.5); with an argument, it checks `headers.txt` captured in LAB_06.

Result before hardening: 10 checks, 7 FAIL — saved in `C13_L3_web_findings.csv`. After LAB_06 only the deliberate part A demonstration stays FAIL.

Run: `python3 C13_L3_web_input_safety.py` · in LAB_06: `python3 C13_L3_web_input_safety.py headers.txt`

INVOICE LOOKUP (LOCAL COPY)

Part D

input `x' OR '1'='1`SQL `... client_code = ?`bound `x' OR '1'='1`**OK** value stays data

rows returned

— #1001 Client 104

— #1002 Client 217

— #1003 Client 388

OUTPUT ENCODING

issue raw: `<script>` runs**OK** encoded: `<script>`; shown as text

SECURITY HEADERS

issue HSTS**issue** CSP**issue** X-Content-Type**issue** X-Frame-Options**issue** Referrer-Policy**check** Server version**issue** cookie flags**PASS 2** **FAIL 7** **WARN 1****OK** review complete — CSV saved

Live visualization in the **HTML** (HyperText Markup Language) module at the last step (Start / Step / Restart buttons).



Five points to remember



1. WPA2-Personal (Wi-Fi Protected Access 2, Personal mode) can be guessed offline from a recorded handshake; **WPA3-SAE** (Wi-Fi Protected Access 3 with Simultaneous Authentication of Equals) forces every guess through the access point and adds forward secrecy. **PMF** (Protected Management Frames) is mandatory in **WPA3** (Wi-Fi Protected Access 3).



2. Bits measure only random choices: 4 or more random words and 15 or more characters, blocklist checks, and a new shared key when someone leaves.



3. Encryption protects the radio link; zoning decides where a device may go. The guest **SSID** (Service Set Identifier) has its own **VLAN** (Virtual Local Area Network), subnet and firewall interface: Internet only.



4. The provider secures facilities, hosts and hypervisor; you secure security group or **NSG** (Network Security Group) rules, identities and data: the fewest actions on the smallest scope.



5. Untrusted input must never become code: parameterized queries, output encoding, and **HTTPS** (Hypertext Transfer Protocol Secure) with security headers.

Supervised work time: your checklist



Add the **Guest zone** row to your zoning table (Chapter 1).



Add the four **GUEST rules** to your LAB_05 rule set on NM-FW01 and test them from NM-GST01: internal addresses blocked, Internet allowed (Chapter 5).



Update the **NM-AP01** entry of your device registry (Chapter 5).



Cloud users: run the Lesson 2 review on your own exports and correct rules and identities. VirtualBox users: check the adapter of every **VM** (Virtual Machine).



Update the **Course Procedure Manual**: date, screenshots, and the **AI** (Artificial Intelligence) disclosure table — or the sentence "No **AI** tools were used in this chapter."



AI rule (Legal Notice §11)

Any use of an **AI** tool in a submission states the **LLM** (Large Language Model) used and the exact prompt(s). **The model drafts. The analyst decides. The analyst's name goes on the record.**



Next class

Wednesday, September 30: Cryptography and Secure Communication, and quiz **Q_03** on Classes 11 to 14. LAB_06 (**VPN** (Virtual Private Network) and **HTTPS** (Hypertext Transfer Protocol Secure)): Classes 16–17.

Where today's examples return in the course

Real-life example	Deliverables	Lab / class	Final Project chapter	Resilience scenario (Chapter 7)
1 - Visitor Wi-Fi at the front desk	Guest zone row; 4 GUEST rules and tests; NM-AP01 registry entry; C13_L1_wifi_findings.csv	Today's work time (LAB_05 review); LAB_06 VPN, Classes 16-17	Chapter 1; Chapter 5	6 (public Wi-Fi); 9 (default credentials)
2 - Website in a free-tier cloud account	Corrected inbound rules or VirtualBox adapter table; identity table; C13_L2_cloud_findings.csv	LAB_06 (UDP 51820, TCP 443), Classes 16-17	Lab environment chapter; Chapter 2 addendum; Chapter 6	2 (password guessing on remote access); 3 (web server compromised)
3 - Client portal before HTTPS	C13_L3_web_findings.csv before and after; header checklist; 301 redirect test	LAB_06 part 2, Class 17	Chapter 6	3 (web server compromised)

Chapters and scenarios as defined in the Final Project and Course Procedure Manual (version 1.0).



Links (1/3) — Lesson 1: wireless security and passphrases

Source	Full address (clickable) — check it with VirusTotal first (Legal Notice §10)
Wi-Fi Alliance — Security (WPA3, PMF, Enhanced Open)	https://www.wi-fi.org/discover-wi-fi/security
Wi-Fi Alliance — WPA3 announcement (June 25, 2018)	https://www.wi-fi.org/news-events/newsroom/wi-fi-alliance-introduces-wi-fi-certified-wpa3-security
Wi-Fi Alliance — Wi-Fi 6E details (6 GHz security)	https://www.wi-fi.org/beacon/chuck-lukaszewski/wi-fi-6e-the-details-you-need-to-know
RFC 7664 — Dragonfly Key Exchange (basis of SAE)	https://www.rfc-editor.org/rfc/rfc7664
RFC 8110 — Opportunistic Wireless Encryption	https://www.rfc-editor.org/rfc/rfc8110
KRACK attacks (2017)	https://www.krackattacks.com/
Dragonblood (2019)	https://wpa3.mathyvanhoef.com/
NIST SP 800-63B-4 — password rules (July 2025)	https://pages.nist.gov/800-63-4/sp800-63b.html
EFF — dice-generated passphrases (7,776 words)	https://www.eff.org/dice
NIST SP 800-153 — securing WLANs	https://csrc.nist.gov/pubs/sp/800/153/final
CCCS ITSP.80.002 — Wi-Fi security	https://www.cyber.gc.ca/en/guidance/wi-fi-security-itsp80002
CCCS ITSAP.80.009 — protecting your organization while using Wi-Fi	https://www.cyber.gc.ca/en/guidance/protecting-your-organization-while-using-wi-fi-itsap80009
CCCS ITSAP.80.023 — guest Wi-Fi	https://www.cyber.gc.ca/en/guidance/guest-wi-fi-itsap80023
OPC — TJX / Winners report (2007)	https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2007/tjx_rep_070925/



Links (2/3) — Lesson 2: virtualization and cloud

Source	Full address (clickable) — check it with VirusTotal first (Legal Notice §10)
AWS — shared responsibility model	https://aws.amazon.com/compliance/shared-responsibility-model/
Microsoft — shared responsibility in the cloud	https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility
AWS — security group rules	https://docs.aws.amazon.com/vpc/latest/userguide/security-group-rules.html
AWS — security groups (stateful behaviour)	https://docs.aws.amazon.com/vpc/latest/userguide/vpc-security-groups.html
AWS — security groups versus network ACLs	https://docs.aws.amazon.com/vpc/latest/userguide/infrastructure-security.html
Microsoft — network security groups	https://learn.microsoft.com/en-us/azure/virtual-network/network-security-groups-overview
AWS — IAM security best practices	https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html
AWS — root user best practices	https://docs.aws.amazon.com/IAM/latest/UserGuide/root-user-best-practices.html
Microsoft — what is Microsoft Entra ID	https://learn.microsoft.com/en-us/entra/fundamentals/whatis
Microsoft — Azure RBAC overview	https://learn.microsoft.com/en-us/azure/role-based-access-control/overview
Oracle — VirtualBox 7.2 networking modes	https://docs.oracle.com/en/virtualization/virtualbox/7.2/user/networkingdetails.html
NIST SP 800-145 — definition of cloud computing	https://csrc.nist.gov/pubs/sp/800/145/final
NIST SP 800-125 — security for full virtualization	https://csrc.nist.gov/pubs/sp/800/125/final
NVD — CVE-2015-3456 (VENOM)	https://nvd.nist.gov/vuln/detail/CVE-2015-3456
CCCS ITSAP.50.111 — models of cloud computing	https://www.cyber.gc.ca/en/guidance/models-cloud-computing-itsap50111
Capital One Canada — 2019 cyber incident facts	https://support.capitalone.ca/cyber/facts2019
U.S. DOJ — Capital One conviction (2022)	https://www.justice.gov/usao-wdwa/pr/former-seattle-tech-worker-convicted-wire-fraud-and-computer-intrusions



Links (3/3) — Lesson 3, privacy law and link safety

Source	Full address (clickable) — check it with VirusTotal first (Legal Notice §10)
OWASP Top 10:2025	https://top10.owasp.org/2025/
OWASP Top 10:2025 — A05 Injection	https://top10.owasp.org/2025/A05_2025-Injection/
OWASP — SQL Injection Prevention Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
OWASP — Cross Site Scripting Prevention Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
OWASP — HTTP Headers Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Headers_Cheat_Sheet.html
MITRE — 2025 CWE Top 25	https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html
CISA — advisory AA23-158A (MOVEit)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a
CISA / FBI — Secure by Design alert on SQL injection	https://www.cisa.gov/resources-tools/resources/secure-design-alert-eliminating-sql-injection-vulnerabilities-software
MDN — Strict-Transport-Security	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security
CCCS ITSM.60.005 — security for your website	https://www.cyber.gc.ca/en/guidance/security-considerations-your-website-itsm60005
CCCS ITSM.10.099 — isolate web-facing applications	https://www.cyber.gc.ca/en/guidance/top-10-security-actions-no-9-isolate-web-facing-applications-itsm10099
CCCS — protecting against credential stuffing	https://www.cyber.gc.ca/en/guidance/strategies-protecting-web-application-systems-against-credential-stuffing-attacks
OPC — Capital One investigation (July 31, 2019)	https://www.priv.gc.ca/en/opc-news/news-and-announcements/2019/an_190731_02/
OPC — PIPEDA	https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/
CAI Québec — Law 25, main changes	https://www.cai.gouv.qc.ca/protection-renseignements-personnels/sujets-et-domaines-dinteret/principaux-changements-loi-25
VirusTotal — URL scanner (check every link first)	https://www.virustotal.com/gui/home/url



Legal Notice — key clauses (1/2)



§5 Assumption of risk, limitation of liability

You use the material at your own risk. Cyber.SoHo and the instructor, in every role, are not responsible for damage, data loss, failures, suspensions, costs or legal consequences from its use or misuse.



§6 No warranty · §7 No professional advice

Provided "as is" and "as available"; tools, prices, links and practices change. Not legal advice, not security consulting: consult qualified professionals and a lawyer licensed in your jurisdiction.



§8 Intellectual property

© 2026 Cyber.SoHo. All rights reserved. Enrolled students receive a limited, personal, non-transferable, non-exclusive license for their own study: no redistribution, re-publication, resale, public posting or commercial use without prior written permission. Your own labs, project and manual belong to you; the instructions and templates remain Cyber.SoHo's.



§13 Indemnification

You agree to indemnify and hold harmless Cyber.SoHo and the instructor from any claim, damage, loss or expense (including reasonable legal fees) resulting from your own actions or omissions, or from your violation of the Legal Notice, a law or a third party's right.



Criminal Code of Canada: s. 342.1, s. 342.2, s. 430(1.1). Also referenced by the course: Québec Law 25, **PIPEDA** (Personal Information Protection and Electronic Documents Act), the **GDPR** (EU 2016/679), the U.S. CFAA (18 U.S.C. §1030), EU Directive 2013/40/EU and Spain's Ley Orgánica 10/1995.

Sources: <https://laws-lois.justice.gc.ca/eng/acts/c-46/section-342.1.html> · <https://www.law.cornell.edu/uscode/text/18/1030> · <https://eur-lex.europa.eu/eli/dir/2013/40/oj>



Legal Notice — key clauses (2/2)



§9 No affiliation

No affiliation with, sponsorship by or endorsement from any organization named, including Oracle (VirtualBox), Amazon (**AWS**), Microsoft (Azure, Entra ID), Netgate (pfSense), Deciso (OPNsense), WireGuard, the Wi-Fi Alliance, **OWASP** (Open Worldwide Application Security Project), MITRE, **NIST** (National Institute of Standards and Technology), the **CIS** (Center for Internet Security), Google (YouTube) and TikTok. Trademarks belong to their owners.



§10 Links · §12 Social media

Links are for convenience; check them with VirusTotal; a link is not an endorsement. Videos on public platforms are third-party content, not verified by Cyber.SoHo; the platform's terms apply.



§11 Ethics and AI

Protect, never harm; respect privacy. Report a real vulnerability responsibly to its owner and to the instructor. **AI** (Artificial Intelligence) use: state the **LLM** (Large Language Model) and the exact prompt(s).



§14 Privacy

The material collects no personal data; this deck and the **HTML** (HyperText Markup Language) module store nothing. The signature log records name, session, date and a verification code.



§15 Governing law

Laws of the Province of Quebec, Canada. An invalid clause leaves the others in force. Version 1.0 replaces all previous ones.



§16 Acceptance

Using the material means accepting the whole document. Sign `Acknowledgment_and_Agreement_eSign.html` each session.



Thank you — see you tomorrow for Class 14

Everything in this deck — full explanations, the three step-by-step programs, flash cards, quizzes, figures, tables and every link — is in the Class 13 **HTML** (HyperText Markup Language) module and its companion files.

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserved